

Perform Session Hijacking Using Various Tools

Execution mode	Authorized, isolated training lab; no public systems were targeted.
Output status	Representative/sanitized lab output recorded for submission. Replace with instructor-required screenshots if a live lab run is performed.

Aim

Demonstrate, in an isolated host-only lab, why reusing an unencrypted session token can grant access to an active web session.

Theory

Session hijacking occurs when an attacker obtains a valid session identifier and the server accepts it as proof of identity. This record uses a synthetic DVWA session and a redacted token. No real user session or public network traffic was used.

Tools and Lab Scope

- Kali Linux
- Ettercap
- Wireshark
- DVWA over HTTP in the host-only lab
- Browser developer tools

Procedure and Recorded Execution

Step 1. Prepare the lab - Place attacker, victim, gateway, and DVWA on 192.168.56.0/24. Confirm the target is synthetic.

```
attacker 192.168.56.10
victim    192.168.56.20
gateway   192.168.56.1
dvwa      192.168.56.30
```

Step 2. Observe the traffic path - In the approved lab only, use a test MITM setup and capture traffic with Wireshark.

```
capture filter: host 192.168.56.20 and http
display filter: http.request
```

Step 3. Identify the test cookie - Locate the synthetic Cookie header and redact the token in the report.

```
Cookie: PHPSESSID=LAB-SESSION-REDACTED
Host: lab-dvwa.local
```

Step 4. Verify controlled reuse - Replace the browser test cookie with the redacted lab value and reload the lab page.

Controlled session reuse output

The lab browser received the authenticated test page after the synthetic session value was reused. This confirms the security impact of transmitting session identifiers over HTTP.

Evidence	Observed result
Protocol	HTTP; cookie visible in the captured request
Token	PHPSESSID=LAB-SESSION-REDACTED
Target	DVWA training instance at 192.168.56.30
Reuse result	Authenticated test page loaded; no real account accessed
Risk	High when session cookies are exposed on an untrusted network

Result

The experiment demonstrated the dependency between token secrecy and session security. Enforcing HTTPS, Secure cookies, and session rotation would prevent this lab scenario.

Safety and Submission Notes

- Use only a host-only network and test accounts.
- Never capture or reuse a real user token.
- Stop the capture immediately after the evidence is collected.

Viva Questions and Answers

What is a session ID?

A server-side reference carried by the client that links requests to an authenticated session.

What is ARP spoofing?

Forged ARP replies that associate an attacker MAC address with another host or gateway IP.

Why does HTTP enable this attack?

HTTP exposes headers and cookies in plaintext; HTTPS encrypts them in transit.

What does Wireshark do?

It captures and decodes packets so authorized testers can inspect protocol fields.

Name a countermeasure.

HTTPS everywhere with HSTS, Secure/HttpOnly/SameSite cookies, and session rotation after login.